

Security+ 2.2 · Common Threat Vectors

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.2** —
Common Threat Vectors (17:14) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Threat vectors are the pathways an attack uses to reach a target: email/SMS/voice, image, file, call, default credentials never changed, infected software, USB baiting, malvertising (malicious ads), credential stuffing (reuse of leaked passwords), insider, remote network, and IoT/cloud/physical vectors.

High-Yield Core Concepts Tested on Exam

- Vectors include: message, file, credential, USB, network, IoT, cloud, and PHYSICAL
- Malvertising: malicious advertisement on a legitimate website
- Credential stuffing = using leaked passwords on other sites (vs brute force)
- Default credentials left unchanged are a common vector
- USB baiting: leaving infected USB drives for victims to plug in

Exam Tips & Classic Scenarios

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising
- 'default credentials never changed' = misconfiguration vector
- If the attack arrives via email attachment or link, the vector is email

Typical Exam Scenario: Scenario: 'An attacker used passwords leaked from a data breach to access other accounts of the same users' = credential stuffing.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.2 — Common Threat Vectors)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In the 'initial access' of modern ransomware, what is the MOST exploited flaw?

- A)** Misconfigured firewall
- B)** Phishing + VPN without MFA / leaked credential
- C)** Exposed network cable
- D)** Lack of antivirus

2. An attacker tests leaked passwords from one site on MULTIPLE other sites (password reuse):

- A) Credential stuffing**
- B) Pure brute force**
- C) Rainbow table**
- D) Vishing**

3. Compromising a software vendor to reach all of its customers (e.g., SolarWinds):

- A) Supply chain attack**
- B) Watering hole**
- C) Insider**
- D) Zero-day**

4. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

5. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Malvertising: malicious ad on a legitimate site'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Malvertising: malicious ad on a legitimate site.**
- D) Allow shared access among administrators using generic credentials**

6. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Credential stuffing = USING a leaked password on other sites (vs brute force)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Credential stuffing = USING a leaked password on other sites (vs brute force).
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'reuses leaked credentials across multiple sites' = credential stuffing. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'reuses leaked credentials across multiple sites' = credential stuffing...

8. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'malicious advertisement on a legitimate website' = malvertising'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'malicious advertisement on a legitimate website' = malvertising...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Typical scenario: attacker used leaked passwords from a data breach on other accounts of the same users = credential stuffing'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Typical scenario: attacker used leaked passwords from a data breach on other accounts of the same users = credential stuffing
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Common Threat Vectors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL...
- D)** Allow shared access among administrators using generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Phishing + VPN without MFA / leaked credential.

✓ **Why it's correct:** The correct answer is: Phishing + VPN without MFA / leaked credential. In the Threats, Vulnerabilities, and Mitigations domain of CompTIA Security+ SY0-701, modern ransomware (such as Ransomware-as-a-Service operations) uses initial access tactics that exploit the human factor and inadequate authentication configurations. Phishing remains the most prevalent vector: malicious emails, social media messages, or fake websites trick users into handing over credentials or executing malicious payloads. Additionally, VPNs without MFA (multi-factor authentication) allow credentials leaked in data breaches or purchased on underground markets to be used directly for remote access to the corporate network. The combination of phishing to obtain credentials and the absence of MFA on VPNs is one of the most exploited flaws, as it bypasses traditional perimeters and gives the attacker legitimate access to the network. CompTIA emphasizes that implementing MFA is a critical mitigation against this vector.

✗ **Why the others are wrong:**

- *Misconfigured firewall:* A misconfigured firewall can allow unauthorized traffic, but it is not the most exploited initial access vector in modern ransomware. Traditional firewalls operate at the network layer and, when properly configured, block exposed ports and services. However, modern attacks often use valid credentials obtained through phishing or leaks, making traffic appear legitimate and not blocked by firewall rules. Furthermore, firewall exploitation typically requires specific vulnerabilities or severe misconfigurations, which are less common than credential compromise. Therefore, it is not the most exploited flaw.
- *Exposed network cable:* An exposed network cable is a physical vulnerability that allows an attacker with local access to connect to the network. Although it is a risk in environments with poor physical access control, it is not a typical initial access vector for modern ransomware, which is generally executed remotely through phishing, exploitation of exposed services, or compromised credentials. Physical attacks require proximity and can be mitigated with physical security, but they do not represent the main entry point for large-scale ransomware campaigns.
- *Lack of antivirus:* The absence of antivirus is a control deficiency, but it is not the most exploited initial access vector. Modern antivirus solutions are effective against known malware, but sophisticated ransomware often uses evasion techniques (obfuscation, fileless, living-off-the-land) that can bypass signature-based solutions. Moreover, initial access occurs before ransomware execution, through compromised credentials or phishing. The lack of antivirus worsens the impact, but it is not the primary flaw that allows the attacker's entry. CompTIA highlights that awareness and MFA are more critical to prevent initial access.

2) A — Credential stuffing.

✓ **Why it's correct:** Credential stuffing is a cyberattack in which the attacker uses lists of credentials (username and password pairs) obtained from data breaches on one site to attempt authentication on multiple other sites, exploiting the common practice of password reuse. The attack is automated and relies on large volumes of leaked credentials. It differs from pure brute force because it does not attempt to guess passwords but uses already known combinations. It is a topic in the Threats, Vulnerabilities, and Mitigations domain of Security+ (SY0-701), objective 2.4, which covers attack techniques.

✗ **Why the others are wrong:**

- *Pure brute force:* Pure brute force is an attack method that exhaustively tries all possible character combinations until it finds the correct password. In credential stuffing, the attacker does not test random combinations; they use credentials previously leaked and valid in another context. Brute

force is computationally intensive and easily detected by account lockouts, while credential stuffing exploits password reuse and can be stealthier because the credentials are legitimate. Therefore, pure brute force does not describe the scenario of testing leaked passwords on multiple sites.

- *Rainbow table*: A rainbow table is a hash-cracking technique that uses precomputed tables of password hashes to reverse cryptographic hash functions. It is used when the attacker obtains password hashes and wants to discover the plaintext passwords. However, the statement describes the use of already leaked passwords (in plaintext or already cracked) to authenticate on other sites, not hash cracking. Rainbow tables do not directly apply to credential stuffing, which does not require breaking encryption but rather exploiting credential reuse.
- *Vishing*: Vishing is a form of social engineering that uses phone calls or voice messages to deceive victims and obtain confidential information, such as passwords or financial data. It does not involve automated testing of leaked credentials across multiple sites. The described scenario is clearly a technical automation attack, not a human persuasion interaction. Therefore, vishing does not apply to the context of credential stuffing, which is a mass attack based on credential lists.

3) A — Supply chain attack.

✓ **Why it is correct:** A supply chain attack occurs when an adversary compromises a vendor, partner, or software/hardware component to reach the end customers of that vendor. In the SolarWinds case (2020), attackers compromised the build process of the Orion software, inserting malicious code that was distributed as a legitimate update to thousands of customers, including government agencies. This is the classic example of a supply chain attack, as described in SY0-701 objective 2.2 (supply chain threats) and 2.3 (attack vectors). The question describes exactly this scenario: compromising a software vendor to reach all of its customers.

✗ **Why the others are wrong:**

- *Watering hole*: A watering hole is an attack in which the adversary compromises a legitimate website frequented by a specific group of victims (e.g., an industrial sector site) and inserts malicious code to infect visitors. The goal is to reach users who visit that site, not to compromise a software vendor to distribute malware to all its customers. In a watering hole, the vector is the third-party site visited by victims; in a supply chain attack, the vector is the vendor's own product or update. The question speaks of compromising a software vendor to reach all its customers, which is supply chain, not watering hole.
- *Insider*: An insider threat refers to an individual with authorized access (employee, contractor, partner) who uses that access to cause harm, steal data, or facilitate attacks. The attacker is internal to the organization, not a compromised external vendor. In the SolarWinds case, the attackers were external (APT29) who compromised SolarWinds' supply chain; it is not an insider of SolarWinds or its customers. Therefore, insider does not describe the scenario of compromising a vendor to reach its customers.
- *Zero-day*: A zero-day refers to a vulnerability unknown to the vendor, for which no patch is available. The attack exploits this flaw before it is fixed. Although supply chain attacks may involve zero-days, the concept of zero-day is about the nature of the vulnerability, not about the vector of compromising a vendor to reach customers. In the SolarWinds case, the attack did not rely exclusively on a zero-day; it involved compromising the build process and distributing a malicious update. The question asks for the name of the attack that compromises a vendor to reach all customers, which is supply chain, not zero-day.

4) B — Implement the corresponding solution: Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): Vectors: message, file, credential, USB, network, IoT, cloud,

PHYSICAL. This correctly identifies the standard threat vector categories that must be assessed and mitigated in a security program.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Malvertising: malicious ad on a legitimate site..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): Malvertising: malicious ad on a legitimate site. Malvertising injects malicious code into legitimate advertising networks or ad slots, allowing attackers to compromise visitors without the site owner's knowledge.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Credential stuffing = USING a leaked password on other sites (vs brute force)..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): Credential stuffing = USING a leaked password on other sites (vs brute force). Credential stuffing leverages previously breached username/password pairs and replays them against other services, exploiting password reuse rather than guessing credentials.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'reuses leaked credentials across multiple sites' = credential stuffing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): 'reuses leaked credentials across multiple sites' = credential stuffing. Credential stuffing is an attack where threat actors take credentials leaked from one breach and automatically try them on other sites, exploiting password reuse. The correct control is to implement defenses against credential stuffing, such as MFA, breached password detection, and rate limiting.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: 'malicious advertisement on a legitimate website' = malvertising....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): 'malicious advertisement on a legitimate website' = malvertising.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Typical scenario: attacker used leaked passwords from a data breach on other accounts of the same users = credential stuffing.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): Typical scenario: attacker used leaked passwords from a data breach on other accounts of the same users = credential stuffing. Credential stuffing exploits password reuse across services.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Common Threat Vectors): Vectors: message, file, credential, USB, network, IoT, cloud, PHYSICAL.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.